

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.

- | | | |
|-------------------------------------|--------------------------|---|
| ☒ | ☐ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |
|-------------------------------------|--------------------------|---|

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional):

High Priority

1. **Implement Access Controls and Data Security Measures:** The most critical vulnerability is the lack of access control, which affects compliance with PCI DSS, GDPR, and SOC standards.
 - o **Action:** Implement **Least Privilege** and **Separation of Duties** to ensure employees can only access data essential to their roles. This will restrict broad access to sensitive data like customer PII/SPII and cardholder information.

- **Action:** Deploy **Encryption** for all stored and transmitted credit card information. This is a fundamental requirement for PCI DSS compliance.
- 2. **Establish Data Backup and Recovery Plans:** The complete absence of data backups and disaster recovery plans poses a significant threat to business continuity.
 - **Action:** Immediately implement a robust **Backups** system for all critical data.
 - **Action:** Develop and document formal **Disaster recovery plans** to ensure the business can recover from a significant outage or data loss event.
- 3. **Strengthen Network and System Security:** While a firewall is in place, other critical security measures are missing.
 - **Action:** Install an **Intrusion Detection System (IDS)** to monitor network traffic for suspicious activity.
 - **Action:** Implement a centralized **Password management system** and enforce a stronger **Password policy** that aligns with current complexity requirements to mitigate unauthorized access.

Medium Priority

1. **Formalize Asset and Data Management:** To comply with GDPR and improve overall security posture, Botium Toys must properly manage its assets.
 - **Action:** Dedicate resources to identify, classify, and inventory all company assets and data. This is essential for understanding what needs to be protected and is a core requirement of GDPR.
2. **Improve Legacy System Management:** While legacy systems are currently monitored, the process lacks formal structure.

- **Action:** Establish and document a regular maintenance schedule and clear intervention methods for all legacy systems to ensure consistent and effective monitoring.